Rate Limiting & Brute-Force Protection

FastAPI Demo — Christina Mastralexi

Overview

A REST API built with FastAPI and two layers of protection on a login endpoint. Rate limiting controls the volume of requests per IP per minute. Brute-force protection tracks failed login attempts and locks out the IP after repeated failures.

Live Demo

The API is temporarily deployed and publicly accessible for testing here:

https://cogninn-test.up.railway.app/docs

Test credentials

```
Username: cogninn          Password: secure123
```

Tests

Scenario	Expected response
POST /login - correct credentials	200 Welcome, cogninn!
POST /login - wrong password (×5)	401 with attempts remaining, then 429 lockout
POST /login - while locked out	429 with seconds remaining until unlock
GET /home - more than 10 times/min	429 Too many requests

Rate limit windows reset after 60 seconds. Brute-force lockout lasts 30 seconds (time limit was set low for testing).

How It Works

Layer	Tool	Trigger
Rate limiting	slowapi	Any request
Brute-force lockout	Redis	Failed logins (401s)

Screenshots on the following page.

```
cmastral@Christinas-MacBook-Air cogninn-test % for i in {1..12}; do
  curl -s -o /dev/null -w "%{http_code}\n" https://cogninn-test.up.railway.app/home
done
200
200
200
200
200
200
200
200
200
200
429
429
```

Curl

```
curl -X 'POST' \
  'https://cogninn-test.up.railway.app/login' \
  -H 'accept: application/json' \
  -H 'Content-Type: application/json' \
  -d '{
  "username": "cogninn",
  "password": "secure123"
}'
```

Request URL

```
https://cogninn-test.up.railway.app/login
```

Server response

Code	Details
200	Response body

```
{
  "message": "Welcome, cogninn!"
}
```

Download

Curl

```
curl -X 'POST' \
  'https://cogninn-test.up.railway.app/login' \
  -H 'accept: application/json' \
  -H 'Content-Type: application/json' \
  -d '{
  "username": "cogninn",
  "password": "ttt"
}'
```

Request URL

```
https://cogninn-test.up.railway.app/login
```

Server response

Code	Details
401 *Undocumented*	Error: response status is 401

Response body

```
{
  "error": "Invalid credentials. 4 attempts left."
}
```

Download

Curl

```
curl -X 'POST' \
  'https://cogninn-test.up.railway.app/login' \
  -H 'accept: application/json' \
  -H 'Content-Type: application/json' \
  -d '{
  "username": "cogninn",
  "password": "ttt"
}'
```

Request URL

```
https://cogninn-test.up.railway.app/login
```

Server response

Code	Details
429 *Undocumented*	Error: response status is 429

Response body

```
{
  "error": "Too many failed attempts. Try again in 26 seconds."
}
```

Download

Curl

```
curl -X 'POST' \
  'https://cogninn-test.up.railway.app/login' \
  -H 'accept: application/json' \
  -H 'Content-Type: application/json' \
  -d '{
  "username": "cogninn",
  "password": "ttt"
}'
```

Request URL

```
https://cogninn-test.up.railway.app/login
```

Server response

Code	Details
429 *Undocumented*	Error: response status is 429 **Response body** `{ "error": "Too many requests." }` Download